

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

Rate-Limit Behaviour Test Evidence - ffuf Run Part 1

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	Rate-limit behaviour
Result Type	ffuf testing evidence
Evidence Report File	10-no-rate-limiting-ffuf-running-p1-evidence-report.pdf
Testing Phase	Resource Consumption and Brute-Force Resistance Testing
Tool / Component	ffuf / Terminal
OWASP / Security Mapping	API4:2023 Unrestricted Resource Consumption
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot

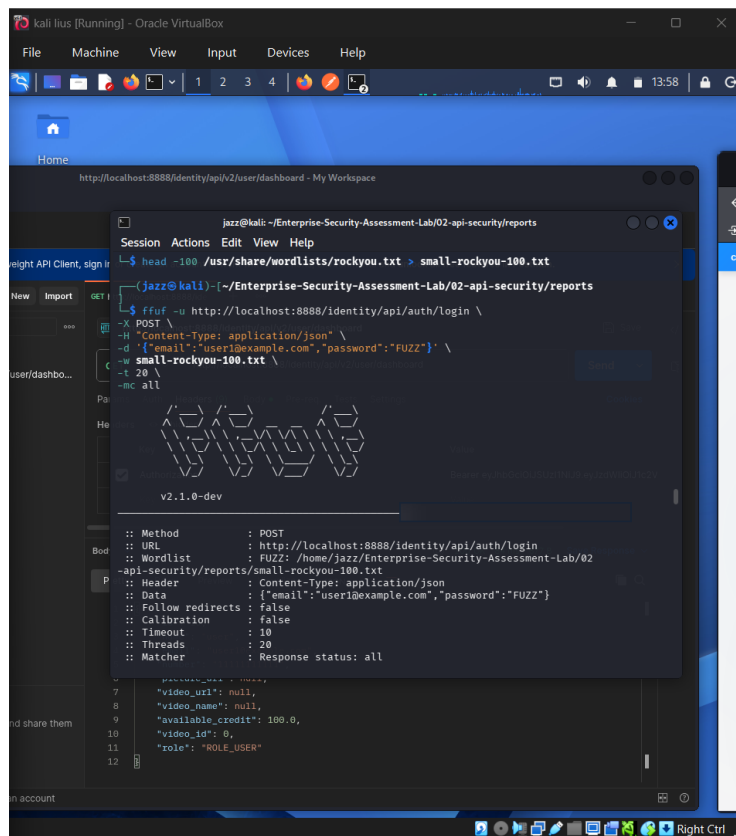


Figure 1 - Embedded screenshot evidence for: Rate-limit behaviour

What this evidence proves

The evidence shows ffuf running against an API endpoint. It demonstrates rate-limit behaviour testing rather than a destructive brute-force attack.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	Resource Consumption and Brute-Force Resistance Testing
Tool / Component	ffuf / Terminal
Assessment Objective	Send controlled repeated requests to assess whether the API applies throttling, blocking, or 429 Too Many Requests responses.
Result Type	ffuf testing evidence
OWASP / Security Mapping	API4:2023 Unrestricted Resource Consumption

Why this evidence matters

Rate limiting protects authentication endpoints, enumeration paths, and resource-intensive APIs from abuse. The test should be controlled and performed only in the lab.

Command / workflow used

```
ffuf -u http://localhost:8888/<endpoint> -w <wordlist> -X POST -H "Content-Type: application/json" -d "<REDACTED>"  
# Review status codes and whether 429/throttling appears
```

Sanitized output style

```
ffuf requests sent in controlled lab  
Status codes observed: <REVIEWED>  
429 responses: <OBSERVED_OR_NOT_OBSERVED>  
No production target involved
```

3. Professional Interpretation

This evidence row should be interpreted as: **ffuf testing evidence**.

If no throttling exists in production, attackers can attempt credential stuffing, brute-force, OTP guessing, scraping, or resource exhaustion.

Assessor notes

Do not claim no rate limiting unless the evidence clearly shows continued accepted requests without throttling.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Finding interpretation

Where the evidence shows vulnerable behaviour, the report should explain the security impact, the affected object or workflow, and the remediation without publishing sensitive raw values.

4. Risk, Impact, and Remediation Guidance

Risk perspective

If no throttling exists in production, attackers can attempt credential stuffing, brute-force, OTP guessing, scraping, or resource exhaustion.

Recommended remediation / hardening actions

- Apply IP-based and user-based rate limits.
- Return 429 for excessive requests.
- Add account lockout or step-up verification where appropriate.
- Monitor repeated failed attempts.
- Use WAF or API gateway throttling.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- Target endpoint if sensitive.
- Request body containing credentials.
- Tokens.
- Emails or usernames in payloads.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

`[Rate-limit behaviour](./reports/evidence/10-no-rate-limiting-ffuf-running-p1-evidence-report.pdf)`

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.